TECHNICKÁ UNIVERZITA V KOŠICIACH
FAKULTA ELEKTROTECHNIKY A INFORMATIKY

# Biometrická autentifikácia tváre s ochranou proti falšovaniu

Semestrálne zadanie z predmetu Biometrické systémy bezpečnosti

Vypracovali: Oleh Poiasnik, [**TODO:** meno spolužiaka]
Vyučujúci: doc. Ing. Matúš Pleva, PhD., Ing. Eva Kupcová, PhD.
Akademický rok: 2026/2027

Košice 2026

# Abstrakt

Práca sa zaoberá prihlasovaním pomocou tváre a ochranou takého prihlasovania pred podvrhmi, ako sú fotografie alebo videá prehrávané na displeji. Navrhli a implementovali sme webový systém, ktorý tvár sníma bežnou webkamerou a o výsledku rozhoduje na serveri. Ochrana je viacvrstvová: kontrola kvality snímky, pasívna detekcia podvrhu dvojicou neurónových sietí MiniFASNet, náhodná výzva na pohyb hlavy a kontrola, že sa osoba počas snímania nezmenila. Tvár sa porovnáva modelom SFace. Na databáze LFW dosiahlo rozpoznávanie EER 2,47 % a pri použitom prahu nulové FAR pri FRR 3,90 %. Pasívna detekcia mala na snímkach z databázy CASIA-FASD EER 5,25 % a pri zvolenom prahu APCER najviac 1,68 %. Všetkých 30 pokusov o prihlásenie statickým obrázkom tváre bolo zamietnutých. Spracovanie jednej relácie trvá na bežnom procesore približne 0,3 s.

**Kľúčové slová:** biometria, rozpoznávanie tváre, detekcia prezentačných útokov, antispoofing, živosť, ISO/IEC 30107-3

# Obsah

**Abstrakt** **1**

**1 Úvod** **6**

**2 Analýza problematiky** **7**

2.1 Ako funguje rozpoznávanie tváre . . . . . 7

2.2 Kvalita biometrickej vzorky . . . . . 8

2.3 Prezentačné útoky . . . . . 8

2.4 Detekcia prezentačných útokov . . . . . 8

2.5 Metriky a normy hodnotenia . . . . . 9

2.6 Ochrana biometrických údajov . . . . . 9

**3 Návrh riešenia** **10**

3.1 Architektúra . . . . . 10

3.2 Biometrický reťazec . . . . . 11

3.3 Návrh aktívnej výzvy . . . . . 13

3.4 Bezpečnostný návrh . . . . . 13

**4 Implementácia** **15**

4.1 Použité technológie . . . . . 15

4.2 Štruktúra projektu . . . . . 15

4.3 Detekcia tváre a kontrola kvality . . . . . 16

4.4 Pasívna detekcia živosti . . . . . 16

4.5 Aktívna výzva a snímanie . . . . . 17

4.6 Registrácia, overenie a identifikácia . . . . . 17

4.7 Bezpečnosť a ochrana údajov . . . . . 18

4.8 Klientska aplikácia . . . . . 19

4.9 Nasadenie . . . . . 21

**5 Testovanie a vyhodnotenie** **22**

5.1 Metriky . . . . . 22

5.2 Automatické testy . . . . . 23

5.3 Presnosť rozpoznávania tváre . . . . . 23
5.4 Presnosť pasívnej detekcie útokov . . . . . 24
5.5 Testy celého systému . . . . . 26
5.6 Výkon . . . . . 28

**6 Príručka a dokumentácia** **29**
6.1 Archivácia a reprodukovateľnosť . . . . . 29
6.2 Inštalácia a spustenie . . . . . 29
6.3 Používateľská príručka . . . . . 31
6.4 Rozhranie REST API . . . . . 32

**7 Záver** **34**

**Zoznam použitej literatúry** **35**

**A Obsah repozitára** **38**

**B Ukážka odpovede API** **39**

# Zoznam obrázkov

3.1 Architektúra systému . . . . . 11
3.2 Spracovanie jednej snímky . . . . . 12

4.1 Úvodná stránka a registrácia . . . . . 19
4.2 Prihlásenie – tvár je v kruhu a spĺňa požiadavky na kvalitu . . . . . 20
4.3 Aktívna výzva počas prihlásenia . . . . . 20
4.4 Používateľský účet a administrácia . . . . . 21

5.1 Rozpoznávanie tváre na LFW . . . . . 24
5.2 Pasívna detekcia prezentačných útokov na CASIA-FASD . . . . . 26

# Zoznam tabuliek


3.1 Vrstvy serverovej časti . . . . . 11
3.2 Model hrozieb a protiopatrenia . . . . . 14

4.1 Použité technológie . . . . . 15

5.1 Pokrytie automatickými testami . . . . . 23
5.2 Výsledky rozpoznávania tváre na LFW (6000 dvojíc) . . . . . 24
5.3 Dataset pre vyhodnotenie pasívnej detekcie (CASIA-FASD, testovacia časť) . . . . . 25
5.4 Chyby pasívnej detekcie pri rôznych prahoch (úroveň snímok) . . . . . 25
5.5 Výsledky pasívnej detekcie útokov na CASIA-FASD (prah 0,50) . . . . 26
5.6 Útok statickým obrázkom . . . . . 27
5.7 Scenáre testu so živými používateľmi . . . . . 27
5.8 Latencia spracovania jednej snímky ($640 \times 360$ px) . . . . . 28

6.1 Najdôležitejšie konfiguračné premenné . . . . . 31
6.2 Časté hlásenia a ich riešenie . . . . . 32
6.3 Hlavné koncové body API (predpona `/api/v1`) . . . . . 32

# Kapitola 1

# Úvod

Odomknúť telefón pohľadom do kamery je dnes úplne bežné a podobne sa tvárou prihlasujeme aj do bankových aplikácií či pri overovaní totožnosti na diaľku. Je to pohodlné – netreba si pamätať heslo a tvár so sebou nosíme stále. Má to však háčik: tvár nie je tajomstvo. Fotku človeka nájdeme na sociálnych sieťach za pár sekúnd a ak ju systém nedokáže odlíšiť od skutočnej osoby, útočník sa prihlási namiesto nej. Správa agentúry ENISA [1] uvádza takéto podvrhy – fotografie, videá prehrávané na displeji či masky – medzi hlavnými hrozbami vzdialeného overovania totožnosti.

Samotné porovnanie dvoch tvárí teda nestačí. Systém musí okrem otázky „je to tá istá osoba?“ zodpovedať aj otázku „je pred kamerou naozaj živý človek?“. Práve tejto oblasti, detekcii prezentačných útokov (angl. *presentation attack detection*, *anti-spoofing*), sme sa v projekte venovali.

Cieľom práce bolo navrhnúť, naprogramovať a otestovať webový systém, ktorý používateľa prihlási iba pomocou tváre z bežnej webkamery a zároveň sa nedá oklamať fotografiou, displejom ani vopred nahraným videom. Nechceli sme sa spoľahnúť na jedinú techniku, preto systém kombinuje viac vrstiev ochrany: kontrolu kvality snímky, neurónovú sieť na pasívnu detekciu podvrhu, náhodnú výzvu na pohyb hlavy a kontrolu, že sa osoba počas snímania nezmenila. Hotový systém je verejne nasadený a jeho zdrojový kód je dostupný na GitHube.

Práca je rozdelená nasledovne. Kapitola 2 stručne vysvetľuje, ako funguje rozpoznávanie tváre, aké útoky naň existujú a ako sa meria úspešnosť biometrických systémov. V kapitole 3 opisujeme návrh riešenia – architektúru, spracovanie snímok a bezpečnostné opatrenia. Kapitola 4 ukazuje, ako sme systém implementovali. V kapitole 5 sú výsledky testovania a vyhodnotenia, kapitola 6 obsahuje príručku k inštalácii a používaniu a na záver zhrnieme dosiahnuté výsledky a možné rozšírenia.

# Kapitola 2

# Analýza problematiky

## 2.1 Ako funguje rozpoznávanie tváre

Rozpoznávanie tváre prebieha v niekoľkých krokoch. Najprv treba tvár v obraze nájsť. Detektor vráti jej polohu a niekoľko orientačných bodov – typicky stredy očí, špičku nosa a kútiky úst. Moderné detektory sú pritom veľmi malé; YuNet má menej ako sto tisíc parametrov a na bežnom procesore zvládne detekciu za niekoľko milisekúnd [2]. Podľa orientačných bodov sa tvár zarovná do jednotnej polohy a veľkosti, aby porovnanie neovplyvnilo, či je hlava mierne naklonená alebo ďalej od kamery.

Zarovnaný výrez tváre spracuje konvolučná neurónová sieť a vytvorí z neho vektor príznakov, akýsi číselný „odtlačok“ tváre. Dobrý vektor má dve vlastnosti: dve fotky toho istého človeka dávajú podobné vektory aj pri inom svetle či výraze a fotky rôznych ľudí dávajú vektory, ktoré sú od seba ďaleko. Podobnosť sa najčastejšie meria kosínusom uhla medzi vektormi a o zhode rozhodne prah. Systém pritom môže pracovať v dvoch režimoch. Pri *verifikácii* (1:1) používateľ tvrdí, kto je, a systém to iba potvrdí porovnaním s jedným uloženým vzorom. Pri *identifikácii* (1:N) systém hľadá najpodobnejší vzor v celej databáze, takže s rastúcim počtom používateľov rastie aj riziko zámeny.

To, ako dobre vektory oddeľujú ľudí, určuje hlavne spôsob trénovania siete. Metóda ArcFace pri trénovaní pridáva medzi triedy (osoby) uhlovú rezervu, takže sieť sa musí naučiť vektory jednej osoby zhlukovať tesnejšie, než by bolo inak potrebné [3]. AdaFace túto rezervu mení podľa kvality obrázka – pri rozmazaných alebo tmavých snímkach je miernejšia, aby sa sieť neučila z nekvalitných dát zlé vzory [4]. SFace, ktorý používame v našom systéme, rieši podobný problém tak, že silu, ktorou sa vektory priťahujú a odpudzujú, obmedzuje sigmoidnou funkciou [5].

## 2.2 Kvalita biometrickej vzorky

Aj najlepší model zlyhá, ak dostane zlú snímku. Rozmazaná, tmavá, príliš malá alebo silno otočená tvár zvyšuje počet odmietnutých oprávnených používateľov a niekedy sa tvár nepodarí ani nájsť. Kvalitu sa preto oplatí kontrolovať ešte pred porovnaním a používateľovi povedať, čo má zlepšiť. Prehľad metód hodnotenia kvality [6] chápe kvalitu ako užitočnosť snímky pre rozpoznávanie, nie ako jej estetiku – pekná, ale z profilu odfotená tvár je pre systém horšia ako obyčajná frontálna fotka z webkamery. Norma ISO/IEC 29794-5 z roku 2025 stanovuje, ako merať jednotlivé vlastnosti fotografie tváre, napríklad ostrosť, osvetlenie, polohu hlavy či otvorené oči, a rozlišuje použitie pri fotografiách do dokladov, pri registrácii a pri bežnom overovaní [7].

## 2.3 Prezentačné útoky

Pri prezentačnom útoku útočník ukáže snímaču podvrh, aby ho systém považoval za inú osobu, alebo aby skryl vlastnú identitu. Prostriedok útoku sa označuje ako PAI (*presentation attack instrument*). Najjednoduchší je vytlačená fotografia, prípadne ohnutá alebo s vystrihnutými očami, aby pôsobila živšie. Častý je aj *replay* útok, pri ktorom útočník ukáže fotografiu alebo video na displeji mobilu či tabletu. Náročnejšie sú papierové, silikónové alebo 3D tlačené masky [8]. Pri hodnotení systému sa každý druh útoku sleduje zvlášť, pretože proti každému pomáhajú iné vlastnosti obrazu.

Od prezentačných útokov treba odlíšiť injekčné útoky. Pri nich útočník kameru úplne obíde a pošle do systému podvrhnutý obraz priamo, napríklad cez virtuálnu kameru alebo upravenú aplikáciu. Takýto obraz nemusí mať žiadne fyzické stopy podvrhu, preto ho detekcia prezentačných útokov sama nezachytí. Agentúra ENISA ich preto uvádza ako samostatnú kategóriu hrozieb a odporúča ich riešiť ďalšími opatreniami, napríklad overením integrity zariadenia [1].

## 2.4 Detekcia prezentačných útokov

Metódy detekcie sa delia na pasívne a aktívne. Pasívne metódy analyzujú samotný obraz a hľadajú stopy podvrhu. Starší prístup využíval ručne navrhnuté príznaky textúry, dnes sa takmer výhradne používajú hlboké neurónové siete, ktoré sa tieto stopy naučia z dát – napríklad textúru papiera, moaré vzniknuté snímaním displeja, odlesky alebo okraje fotografie [9]. Ich výhodou je, že používateľ nemusí nič robiť. Nevýhodou je, že model vie dobre rozpoznať iba to, čo videl pri trénovaní.

Práve generalizácia je hlavným otvoreným problémom. Model natrénovaný na jednom datasete často zlyhá pri inej kamere, inom osvetlení alebo novom type útoku. Výskum sa preto zameriava na metódy, ktoré lepšie oddelia živé tváre od podvrhov

aj v nových podmienkach [10], alebo využívajú veľké predtrénované modely spájajúce obraz a text [11]. Súťaže na rozsiahlych dátach z reálneho sveta zároveň ukazujú, že výsledky z laboratórnych datasetov sa do praxe prenášajú len čiastočne [12].

Aktívne metódy naopak žiadajú od používateľa spoluprácu – má žmurknúť, usmiať sa alebo otočiť hlavu určeným smerom (tzv. *challenge–response*). Statická fotografia takúto akciu nevykoná a ak je poradie akcií náhodné, nepomôže ani vopred nahrané video. Cenou je o niečo dlhšie a menej pohodlné prihlásenie. V praxi sa preto oba prístupy často kombinujú, čo je aj prístup nášho systému.

## 2.5 Metriky a normy hodnotenia

Presnosť rozpoznávania opisujú dve chyby: FAR (podiel prijatých cudzích osôb) a FRR (podiel odmietnutých oprávnených používateľov). Obe závisia od prahu – prísnejší prah znižuje FAR, ale zvyšuje FRR. Systémy sa preto porovnávajú pomocou EER, teda hodnoty, pri ktorej sú obe chyby rovnaké, alebo pomocou krivky DET, ktorá ukazuje celý kompromis naraz. Pre bezpečnostné aplikácie sa často uvádza aj FRR pri pevnom, veľmi nízkom FAR.

Pre detekciu prezentačných útokov definuje metriky norma ISO/IEC 30107-3 [13]. APCER je podiel útokov, ktoré systém nesprávne prijal ako živú tvár, a počíta sa zvlášť pre každý druh útoku; rozhodujúci je najhorší z nich. BPCER je podiel skutočných používateľov, ktorých systém nesprávne označil za útok. V literatúre sa často uvádza aj ACER, priemer APCER a BPCER, no norma takéto priemerovanie neodporúča, pretože skrýva, či systém zlyháva v bezpečnosti alebo v pohodlí [14]. Vhodnejšie je uvádzať BPCER pri pevnej hodnote APCER, napríklad BPCER20 pri APCER 5 %.

## 2.6 Ochrana biometrických údajov

Biometrické údaje, ktoré slúžia na jednoznačnú identifikáciu osoby, patria podľa GDPR medzi osobitné kategórie osobných údajov a ich spracovanie vyžaduje výslovný súhlas. Na rozdiel od hesla sa tvár po úniku nedá zmeniť, preto treba chrániť aj uložené vzory. Od ochrany sa očakáva, že z uloženého vzoru nepôjde zrekonštruovať pôvodnú tvár, že vzory z rôznych systémov sa nebudú dať prepojiť a že kompromitovaný vzor pôjde nahradiť novým. Používajú sa na to napríklad zrušiteľná biometria, biometrické kryptosystémy alebo homomorfné šifrovanie [15]. Od roku 2024 platí v EÚ aj akt o umelej inteligencii, ktorý systémy diaľkovej biometrickej identifikácie zaraďuje medzi vysokorizikové. Výnimkou je biometrická verifikácia, ktorej jediným účelom je potvrdiť, že osoba je tá, za ktorú sa vydáva [16].

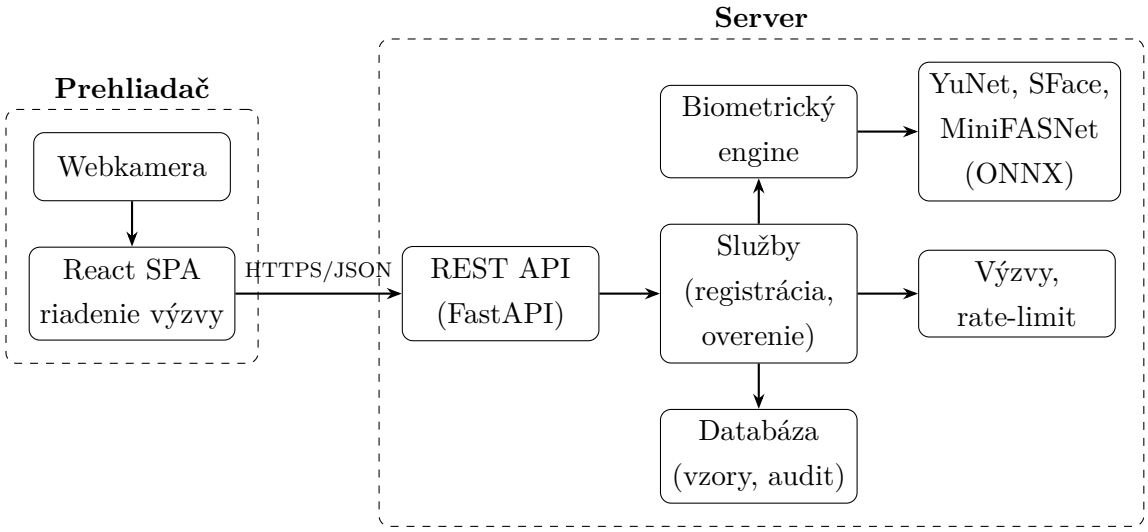
# Kapitola 3

# Návrh riešenia

Cieľom praktickej časti bolo vytvoriť funkčný webový systém, ktorý používateľa autentifikuje iba pomocou tváre snímanej bežnou webkamerou a ktorý zároveň odolá najčastejším prezentačným útokom – fotografii, displeju s fotografiou alebo videom a pokusu o zámenu osoby počas snímania. Kapitola opisuje architektúru, biometrický reťazec a bezpečnostný návrh. Implementačné detaily nasledujú v kapitole 4.

## 3.1 Architektúra

Systém má klient-server architektúru (obr. 3.1). Klient je jednostránková aplikácia (SPA) v jazyku TypeScript s knižnicou React, ktorá ovláda webkameru cez rozhranie `getUserMedia`, zobrazuje pokyny a odosiela snímky na server. Server je napísaný v jazyku Python s rámcom FastAPI a obsahuje celý biometrický reťazec. Všetky rozhodnutia o živosti a zhode robí server – kód v prehliadači môže útočník ľubovoľne upraviť, preto mu nemožno dôverovať. Trvalé dáta sú v relačnej databáze (SQLite pri vývoji, PostgreSQL v produkcii), krátkodobý stav (jednorazové výzvy, počítadlá pokusov) v pamäti procesu alebo v Redise.




Obr. 3.1: Architektúra systému

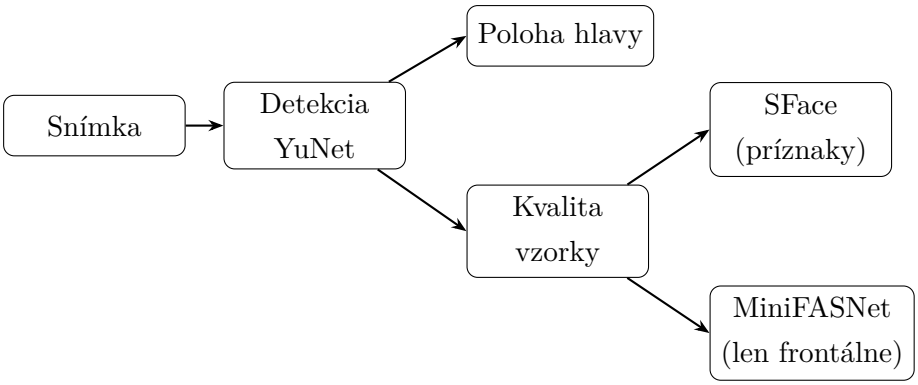
Serverová časť je rozdelená do vrstiev (tab. 3.1). Biometrické komponenty sú definované cez rozhrania – detektor, extraktor príznakov a pasívny detektor živosti možno vymeniť bez zmeny zvyšku systému a v testoch ich nahradiť deterministickými náhradami. Všetky objekty sa skladajú na jednom mieste aplikácie.

Tabuľka 3.1: Vrstvy serverovej časti

| Vrstva | Balík | Zodpovednosť |
|---|---|---|
| Prezentačná | `app/api` | HTTP rozhranie, validácia vstupov, autentifikácia JWT, mapovanie chýb |
| Aplikačná | `app/services` | prípady použitia, transakcie, audit, dočasné zablokovanie účtu |
| Doménová | `app/biometrics` | detekcia, kvalita, živosť, príznaky, rozhodovanie |
| Infraštruktúrna | `app/db`, `app/core` | databáza, šifrovanie, konfigurácia, Redis |

## 3.2 Biometrický reťazec

Každá snímka prechádza rovnakým spracovaním (obr. 3.2). Najprv detektor YuNet [2] nájde tváre a päť orientačných bodov (stredy očí, špička nosa, kútiky úst). Z orientačných bodov sa hneď vypočíta poloha hlavy – aj vtedy, keď snímka nesplní požiadavky na kvalitu, pretože počas otáčania hlavy je obraz často mierne rozmazaný. Ak snímka kvalitu spĺňa, model SFace [5] z nej vytvorí 128-rozmerný vektor príznakov a pri frontálnych snímkach dvojica modelov MiniFASNet odhadne pravdepodobnosť, že ide o živú tvár.




Obr. 3.2: Spracovanie jednej snímky

Rozhodnutie sa však nerobí na základe jednej snímky, ale celej *relácie*. Relácia je postupnosť snímok zachytených počas jednej náhodnej výzvy. Server ju vyhodnotí v piatich krokoch a pri prvom neúspešnom kroku ju zamietne s konkrétnym dôvodom:

1. **Kvalita** – relácia musí obsahovať aspoň jednu použiteľnú frontálnu snímku (dôvod `quality`).

2. **Pasívna detekcia** – priemerné skóre živosti frontálnych snímok musí byť aspoň $\tau_{\text{PAD}} = 0{,}50$ a žiadna z nich nesmie klesnúť pod 0,20 (dôvod `passive_spoof`).

3. **Aktívna výzva** – v každom kroku výzvy musí byť zaznamenaný požadovaný pohyb hlavy (dôvod `active_challenge_failed`).

4. **Konzistencia identity** – každá snímka relácie musí byť podobná vzoru relácie aspoň na 0,30 (dôvod `identity_inconsistent`).

5. **Porovnanie** – vzor relácie sa porovná s uloženým vzorom (1:1) alebo s galériou (1:N); zhoda nastane pri kosínusovej podobnosti $s \geq \tau_{\text{match}} = 0{,}40$ (dôvod `no_match`).

Pasívna detekcia sa počíta iba na frontálnych snímkach, pretože modely MiniFASNet boli trénované na tvárach otočených do kamery a pri otočenej hlave dávajú zbytočne nízke skóre. Prah 0,50 sme zvolili na základe merania v kapitole 5. Vzor relácie je normalizovaný priemer vektorov príznakov frontálnych snímok:

$$\mathbf{t} = \frac{\sum_i \hat{\mathbf{e}}_i}{\left\|\sum_i \hat{\mathbf{e}}_i\right\|}, \qquad s(\mathbf{t}, \mathbf{r}) = \mathbf{t}^\top \hat{\mathbf{r}}, \tag{3.1}$$

kde $\hat{\mathbf{e}}_i$ sú L2-normalizované vektory príznakov a $\hat{\mathbf{r}}$ je normalizovaný referenčný vzor. Prah 0,40 je mierne prísnejší ako hodnota 0,363, ktorú pre model SFace odporúča knižnica OpenCV [17]; meranie na LFW ukázalo, že pri ňom nevznikla ani jedna falošná zhoda.

## 3.3 Návrh aktívnej výzvy

Pasívna detekcia sa učí z dát a jej úspešnosť v nových podmienkach (iná kamera, iné osvetlenie) nie je zaručená [10]. Preto ju dopĺňa aktívna výzva typu *challenge–response*. Server pri každom pokuse vygeneruje kryptograficky bezpečným generátorom postupnosť

$$\texttt{center} \to a_1 \to a_2, \qquad a_1 \neq a_2 \in \{\texttt{turn_left}, \texttt{turn_right}, \texttt{look_up}, \texttt{look_down}\},$$

teda 12 možných poradí. Výzva má 192-bitový identifikátor, platí 90 s a po prvom použití sa zmaže. Statická fotografia nemôže vykonať pohyb a vopred nahrané video nepozná náhodné poradie.

Poloha hlavy sa odhaduje geometricky z piatich orientačných bodov. Body sa najprv otočia tak, aby spojnica očí bola vodorovná (kompenzácia náklonu hlavy). Potom

$$\text{yaw} = \frac{x_{\text{nos}} - x_{\text{oči}}}{d_{\text{oči}}}, \qquad \text{pitch} = \frac{y_{\text{nos}} - y_{\text{oči}}}{y_{\text{ústa}} - y_{\text{oči}}}, \tag{3.2}$$

kde $x_{\text{oči}}, y_{\text{oči}}$ je stred spojnice očí, $d_{\text{oči}}$ vzdialenosť očí a $y_{\text{ústa}}$ výška stredu úst. Pri otočení hlavy doľava (z pohľadu osoby) sa nos posunie doprava v nezrkadlenom obraze a yaw rastie; pri pohľade hore sa nos priblíži k línii očí a pitch klesá.

Krok `center` určí osobnú neutrálnu polohu $(\overline{\text{yaw}}, \overline{\text{pitch}})$ ako medián. Ostatné kroky sa hodnotia ako zmena oproti nej – tým sa odstráni vplyv individuálnej stavby tváre aj toho, že kamera nie je presne pred používateľom. Krok je splnený, ak aspoň dve snímky prekročia prah (0,20 pre yaw, 0,07 pre pitch) v správnom smere a aspoň polovica snímok kroku obsahuje detegovanú tvár.

Prvá verzia klienta snímala každý krok pevne stanovený čas. Ak používateľ začal pohyb neskôr, v odoslaných snímkach ho nemuselo byť dosť a krok zlyhal, hoci ho používateľ vykonal. Výzvu sme preto prerobili na adaptívnu: klient počas kroku posiela serveru aj malé náhľadové snímky, server vráti aktuálnu polohu hlavy a keď pohyb prekročí prah, klient krok o 0,6 s neskôr ukončí (najneskôr po 5 s). Toto meranie slúži iba na navádzanie používateľa – konečné rozhodnutie urobí server znova zo všetkých odoslaných snímok, takže upravený klient nemôže výzvu obísť.

## 3.4 Bezpečnostný návrh

Tabuľka 3.2 sumarizuje uvažované hrozby a zodpovedajúce protiopatrenia. Kategorizácia útokov vychádza z normy ISO/IEC 30107-3 [13] a zo správy ENISA o vzdialenom overovaní totožnosti [1].

Tabuľka 3.2: Model hrozieb a protiopatrenia

| Hrozba | Protiopatrenie |
|---|---|
| Vytlačená fotografia | MiniFASNet (textúra, okraje papiera); nemožnosť vykonať pohyb |
| Fotografia / video na displeji | MiniFASNet (moaré, rám displeja); náhodné poradie pohybov |
| Nahrávka s pohybmi hlavy | náhodná jednorazová výzva s krátkou platnosťou |
| Zámena osoby počas snímania | konzistencia vektorov príznakov všetkých snímok |
| Opakované odoslanie požiadavky | výzva sa po použití atomicky zmaže |
| Hrubá sila, ladenie podľa skóre | zablokovanie po 5 neúspechoch za 15 min, limit požiadaviek na IP, skóre sa v produkcii nevracajú |
| Zisťovanie existencie účtov | neznámy používateľ dostane rovnakú odpoveď `no_match` |
| Únik databázy | šifrovanie vzorov (Fernet: AES-128-CBC + HMAC-SHA256), kľúč mimo databázy |
| Duplicitná registrácia | vyhľadanie 1:N v galérii pri registrácii |
| Injekcia snímok (virtuálna kamera) | iba čiastočne (PAD, výzva); úplná ochrana vyžaduje atestáciu zariadenia |

Ochrana uložených vzorov je navrhnutá s ohľadom na to, že biometrický údaj nemožno po úniku zmeniť ako heslo [15]. Systém preto neukladá fotografie, vzor šifruje a umožňuje používateľovi kedykoľvek vymazať účet aj vzor. Každý pokus o prihlásenie do účtu – aj zamietnutý pre podvrh – sa zobrazí v histórii jeho vlastníka, takže používateľ vidí, ak sa niekto pokúšal prihlásiť namiesto neho.

# Kapitola 4

# Implementácia

## 4.1 Použité technológie

Tabuľka 4.1: Použité technológie

| Oblasť | Technológia |
|---|---|
| Server | Python 3.12, FastAPI, Pydantic, Uvicorn |
| Databáza | SQLAlchemy 2, Alembic (migrácie), SQLite / PostgreSQL |
| Biometria | OpenCV (YuNet [2], SFace [5]), ONNX Runtime (MiniFASNet [18]) |
| Bezpečnosť | PyJWT (prístupové tokeny), cryptography/Fernet (šifrovanie vzorov) |
| Klient | TypeScript, React 19, React Router, Vite |
| Kvalita kódu | pytest, Ruff, mypy, ESLint, Vitest, GitHub Actions |
| Nasadenie | Docker, docker compose, nginx, Render (server), Vercel (klient) |

Všetky neurónové siete sú predtrénované a voľne dostupné. Sťahuje ich skript `scripts/download_models.py`, ktorý zároveň uloží kontrolné súčty SHA-256. Spolu majú približne 42 MB a bežia na CPU.

## 4.2 Štruktúra projektu

```
backend/
  app/
    api/            HTTP rozhranie (routy, závislosti)
    biometrics/     detektor, príznaky, kvalita, žťivos, engine
      liveness/     pasívna detekcia, aktívna výzva, póza hlavy
    core/           konfigurácia, JWT, šifrovanie, chyby, rate-limit
    db/             ORM modely, pripojenie, migrácie
    repositories/   prístup k dátam
```

```
    services/       registrácia, overenie, identifikácia, výzvy
  evaluation/       metriky ISO/IEC, vyhodnocovacie skripty, grafy
  tests/            jednotkové a end-to-end testy
frontend/src/
  api/  auth/  biometrics/  camera/  components/  pages/
docs/               dokumentácia
report/             táto správa (LaTeX)
```

## 4.3 Detekcia tváre a kontrola kvality

Detektor YuNet sa volá cez triedu `cv2.FaceDetectorYN`. Pre každú tvár vráti ohraničujúci obdĺžnik, päť orientačných bodov a skóre. Tváre sa zoradia podľa plochy a ďalej sa pracuje s najväčšou. Keďže objekt OpenCV si pamätá veľkosť vstupu, prístup k nemu chráni zámok, aby boli súbežné požiadavky bezpečné.

Kontrola kvality (trieda `QualityAssessor`) je inšpirovaná normou ISO/IEC 29794-5 [7], ale je zjednodušená na rýchle a ľahko vysvetliteľné kritériá:

- v zábere nesmie byť ďalšia tvár väčšia ako 15 % plochy hlavnej tváre,
- kratšia strana tváre aspoň 80 px,
- ostrosť – rozptyl Laplaciánu na výreze tváre zmenšenom na $128 \times 128$ px aspoň 12,
- priemerný jas výrezu v intervale $\langle 40, 225 \rangle$.

Výsledkom je zoznam problémov (napr. `too_dark`), ktoré klient zobrazí ako krátku radu („Je príliš tma“). Rovnaká kontrola beží aj ako samostatný endpoint `/biometrics/quality`, ktorý klient volá počas nastavovania tváre a ktorý vracia aj aktuálnu polohu hlavy. Prvá verzia mala hranice prísnejšie (90 px, ostrosť 25, jas od 50). Bežné notebookové kamery však pri horšom osvetlení dávajú tmavší a menej ostrý obraz, preto sme hranice zmiernili.

## 4.4 Pasívna detekcia živosti

Použité sú dva modely MiniFASNet (V2 a V1SE) z projektu Silent-Face-Anti-Spoofing [18], exportované do formátu ONNX. Každý model dostane výrez tváre zväčšený 2,7× resp. 4× oproti ohraničujúcemu obdĺžniku, aby videl aj okolie tváre (rám displeja, okraj papiera), zmenšený na $80 \times 80$ px. Vstupom je obraz BGR s hodnotami 0–255 vo

formáte NCHW, výstupom softmax nad troma triedami, z ktorých trieda 1 znamená živú tvár. Výsledné skóre je vážený priemer oboch modelov:

$$p_{\text{live}} = \frac{\sum_m w_m \, p_m(\text{live})}{\sum_m w_m}. \tag{4.1}$$

Listing 4.1: Predspracovanie a inferencia jedného modelu (zjednodušené)

```
crop = crop_with_context(image, face.bbox, scale, (80, 80))
tensor = np.transpose(crop.astype(np.float32), (2, 0, 1))[None]
logits = session.run(None, {input_name: tensor})[0]
p_live = softmax(logits)[0, LIVE_CLASS_INDEX]
```

## 4.5 Aktívna výzva a snímanie

Výzvy vydáva a overuje trieda `ChallengeService`. Výzva sa uloží pod náhodným identifikátorom (`secrets.token_urlsafe(24)`) s dobou platnosti 90 s. Pri overení sa výzva z úložiska odstráni atomickou operáciou (v Redise `GETDEL`), takže tú istú výzvu nemožno použiť dvakrát. Overuje sa aj účel výzvy – výzva vydaná na prihlásenie nemôže byť použitá na registráciu.

Na strane klienta snímanie riadi hook `useLivenessCapture`. Každých 220 ms skopíruje aktuálny snímok z videa cez `canvas` (bez zrkadlenia, zmenšený na šírku 640 px, JPEG). Krok `center` trvá 1,6 s. V pohybových krokoch zároveň posiela náhľady na `/biometrics/quality` a zo vrátenej polohy hlavy počíta, koľko z požadovaného pohybu už používateľ urobil. Tento podiel sa zobrazuje ako vyplnenie kruhového ukazovateľa okolo náhľadu kamery. Keď pohyb dosiahne prah, krok sa o 0,6 s neskôr ukončí, inak najneskôr po 5 s. Z každého kroku sa odošle najviac 10 posledných snímok, celá relácia má teda najviac 27 snímok.

Na serveri vyhodnotenie výzvy (trieda `ActiveLivenessVerifier`) vypočíta pre každú snímku polohu hlavy a pohyb oproti neutrálnej polohe v smere požadovanej akcie. Ak niektorý krok neuspeje, odpoveď obsahuje názov tohto kroku a klient používateľovi presne povie, ktorý pohyb nerozpoznal („Nerozpoznali sme otočenie hlavy doprava“).

## 4.6 Registrácia, overenie a identifikácia

Prípady použitia implementuje trieda `BiometricAuthService`. Všetky majú rovnaký priebeh: spotrebovanie výzvy, kontrola, že snímky pokrývajú všetky kroky, dekódovanie obrázkov s limitom veľkosti, vyhodnotenie relácie a nakoniec akcia podľa prípadu použitia:

- **registrácia** – kontrola obsadenosti mena, vyhľadanie tváre v galérii (odmietnutie duplicitnej registrácie), uloženie používateľa a šifrovaného vzoru;
- **verifikácia 1:1** – kontrola dočasného zablokovania, porovnanie so vzormi používateľa; neexistujúci používateľ dostane rovnakú chybu ako nezhoda;
- **identifikácia 1:N** – porovnanie so všetkými vzormi aktívnych používateľov a výber najlepšej zhody nad prahom;
- **aktualizácia vzoru** – nový vzor sa uloží, iba ak sa zhoduje s pôvodným, čo bráni prevzatiu účtu po krádeži tokenu.

Každý pokus sa zapíše do auditného záznamu (režim, výsledok, dôvod zamietnutia, skóre zhody a živosti, výsledok výzvy, počet snímok, čas spracovania, IP adresa). Záznam sa zapisuje v samostatnej transakcii až po potvrdení alebo zrušení hlavnej transakcie, takže zostane zachovaný aj pri neúspechu. Z auditu sa počíta aj dočasné zablokovanie účtu.

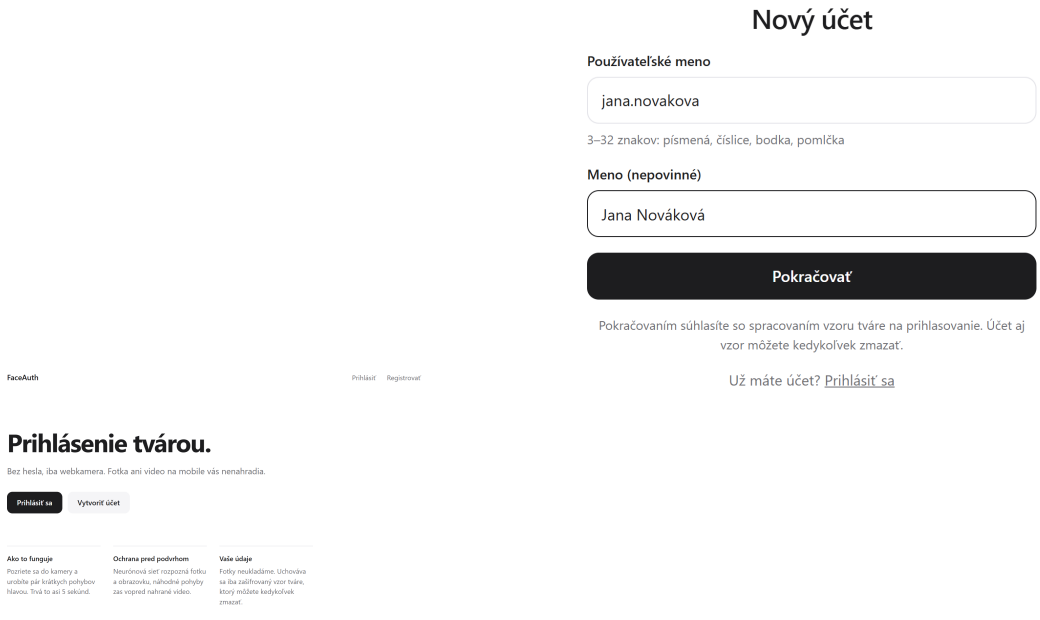
## 4.7 Bezpečnosť a ochrana údajov

- **Šifrovanie vzorov** – vektor 128 hodnôt typu `float32` sa šifruje schémou Fernet. Kľúč je v premenných prostredia, nie v databáze. Vzor je viazaný na verziu modelu, po výmene modelu sa starý vzor nepoužije.
- **Prístupové tokeny** – JWT podpísané HMAC-SHA256 s platnosťou 30 min.
- **Ochrana proti zneužitiu** – limit požiadaviek na IP adresu, limit veľkosti požiadavky (20 MB), snímky (2 MB) a počtu snímok (50); obrázky sa zmenšia na najviac 1280 px.
- **Produkčný režim** – aplikácia odmietne štartovať bez nastavených tajomstiev; v odpovediach sa nevracajú skóre, aby útočník nemohol vstup postupne ladiť podľa nich; vypnutá je dokumentácia API.
- **Klient** – prísna politika CSP, zákaz vkladania do rámcov, token v úložisku `sessionStorage` (zanikne zatvorením karty).
- **GDPR** – používateľ môže vymazať účet aj vzor; pri registrácii je informovaný o spracovaní biometrického údaja.

## 4.8 Klientska aplikácia

Pri návrhu rozhrania sme sa inšpirovali existujúcimi aplikáciami na prihlásenie tvárou, napríklad nastavením Face ID v systéme iOS: veľký kruhový náhľad kamery, okolo neho prstenec z čiarok, ktorý sa postupne vypĺňa, a pod ním jedna krátka veta s pokynom. Rozhranie je zámerne jednoduché – bez vysvetľujúcich odsekov, s jedným hlavným tlačidlom na obrazovke. Ak je tvár v kruhu v poriadku, prstenec sa zafarbí nazeleno (obr. 4.2). Počas pohybového kroku sa vo vnútri kruhu zobrazí šípka v smere pohybu (obr. 4.3a) a po neúspechu sa prstenec zafarbí načerveno a pod ním je dôvod zamietnutia (obr. 4.3b). Náhľad je zrkadlený, aby pokyn „doľava“ zodpovedal smeru, ktorý používateľ vidí.

Snímky obrazoviek v tejto kapitole boli vytvorené s virtuálnou kamerou, ktorej obraz tvorila verejne dostupná, umelo vygenerovaná fotografia tváre (StyleGAN, voľné dielo). Ide teda zároveň o ukážku útoku statickým obrázkom – systém ho podľa očakávania zamietol, pretože obraz sa počas výzvy nepohol.




(a) Úvodná stránka (b) Registrácia – prvý krok

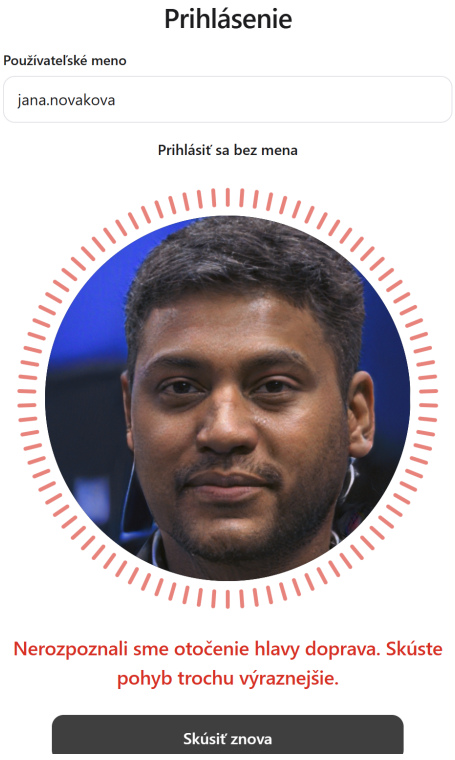
Obr. 4.1: Úvodná stránka a registrácia




Obr. 4.2: Prihlásenie – tvár je v kruhu a spĺňa požiadavky na kvalitu

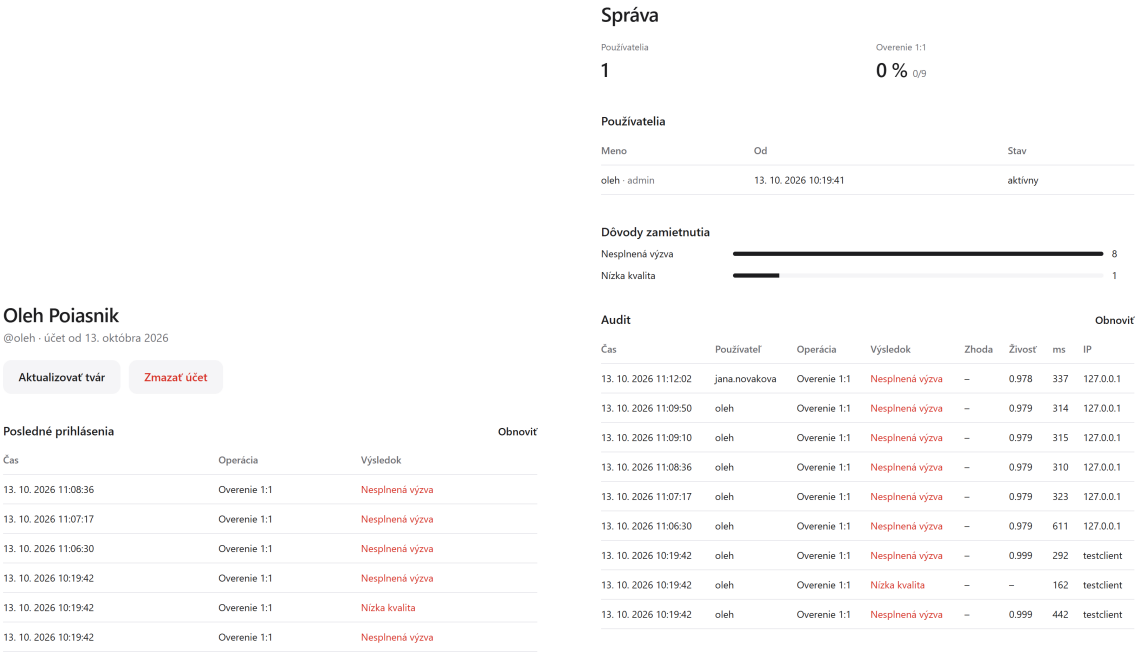



(a) Krok výzvy „Otočte hlavu doprava“




(b) Zamietnutie statického obrázka

Obr. 4.3: Aktívna výzva počas prihlásenia




(a) Účet s históriou pokusov

(b) Správa systému

Obr. 4.4: Používateľský účet a administrácia

Technicky sa klient skladá z troch častí. Hook `useCamera` spúšťa a zastavuje webkameru a prekladá chyby prehliadača na zrozumiteľné hlásenia. Pri testovaní sme v ňom našli súbeh: ak sa kamera spustila dvakrát rýchlo po sebe (napríklad pri rýchlom prechode medzi stránkami), druhé spustenie prerušilo prvé a aplikácia nesprávne hlásila, že kamera nie je dostupná. Oprava každé spustenie očísluje a výsledky neaktuálnych spustení zahodí. Hook `useQualityMonitor` pred začiatkom snímania pravidelne kontroluje kvalitu a `useLivenessCapture` riadi samotnú výzvu. Chyby zo servera sa podľa kódu a dôvodu zamietnutia prekladajú na krátke slovenské hlásenia.

## 4.9 Nasadenie

Server aj klient majú vlastný `Dockerfile`. Lokálne sa celý systém spustí príkazom `docker compose up`: kontajner nginx poskytuje statické súbory klienta a presmerúva `/api` na server, server pri štarte spustí databázové migrácie a Redis zdieľa výzvy medzi procesmi. Verejná inštancia beží na službách Render (server s PostgreSQL, definícia v `render.yaml`) a Vercel (klient, `vercel.json`), pričom Vercel presmerúva `/api` na server – prehliadač tak komunikuje iba s jednou doménou.

- Aplikácia: `https://face-auth-antispoofing.vercel.app`
- Repozitár: `https://github.com/opoiasnik/face-auth-antispoofing`

# Kapitola 5

# Testovanie a vyhodnotenie

Systém sme overili na štyroch úrovniach: (1) automatické testy softvéru, (2) meranie presnosti rozpoznávania na verejnej databáze LFW, (3) meranie pasívnej detekcie útokov na verejnej databáze CASIA-FASD a (4) testy celého systému cez jeho rozhranie. Výkon sme merali samostatne. Všetky vyhodnocovacie skripty sú v priečinku `backend/evaluation` a výsledky ukladajú ako tabuľky (JSON, CSV, Markdown) a grafy (PNG, PDF).

## 5.1 Metriky

### Rozpoznávanie tváre

Pri prahu $\tau$ a skóre porovnaní genuine $G$ (rovnaká osoba) a impostor $I$ (rôzne osoby):

$$\mathrm{FAR}(\tau) = \frac{|\{s \in I : s \geq \tau\}|}{|I|}, \qquad \mathrm{FRR}(\tau) = \frac{|\{s \in G : s < \tau\}|}{|G|}. \tag{5.1}$$

Miera rovnakej chyby (EER) je hodnota v bode $\mathrm{FAR}(\tau) = \mathrm{FRR}(\tau)$; počíta sa lineárnou interpoláciou medzi susednými prahmi. Ďalej uvádzame FRR pri pevnom FAR (1 % a 0,1 %) a podiel snímok bez detegovanej tváre (FTA).

### Detekcia prezentačných útokov

Podľa ISO/IEC 30107-3 [13] sa pre každý druh útoku $k$ počíta

$$\mathrm{APCER}_k = \frac{\text{útoky typu } k \text{ prijaté ako živá tvár}}{\text{všetky útoky typu } k}, \qquad \mathrm{BPCER} = \frac{\text{odmietnuté živé tváre}}{\text{všetky živé tváre}}, \tag{5.2}$$

pričom celkové $\mathrm{APCER} = \max_k \mathrm{APCER}_k$. Uvádzame aj BPCER20 a BPCER100, teda BPCER pri prahu, pri ktorom $\mathrm{APCER} \leq 5$ % resp. 1 %, a pre porovnanie s literatúrou aj ACER.

## 5.2 Automatické testy

Serverová časť má 49 testov (pytest) s pokrytím kódu 87 %. Testy nahrádzajú neurónové siete deterministickými náhradami: syntetická snímka nesie v jednom pixeli identitu, polohu hlavy a príznak živosti. Vďaka tomu sa celý tok overuje cez skutočné HTTP rozhranie bez modelov a bez GPU. Klient má 7 jednotkových testov v nástroji Vitest. Testy, statická analýza (Ruff, mypy, ESLint) a zostavenie Docker obrazov bežia automaticky pri každej zmene v GitHub Actions.

Tabuľka 5.1: Pokrytie automatickými testami

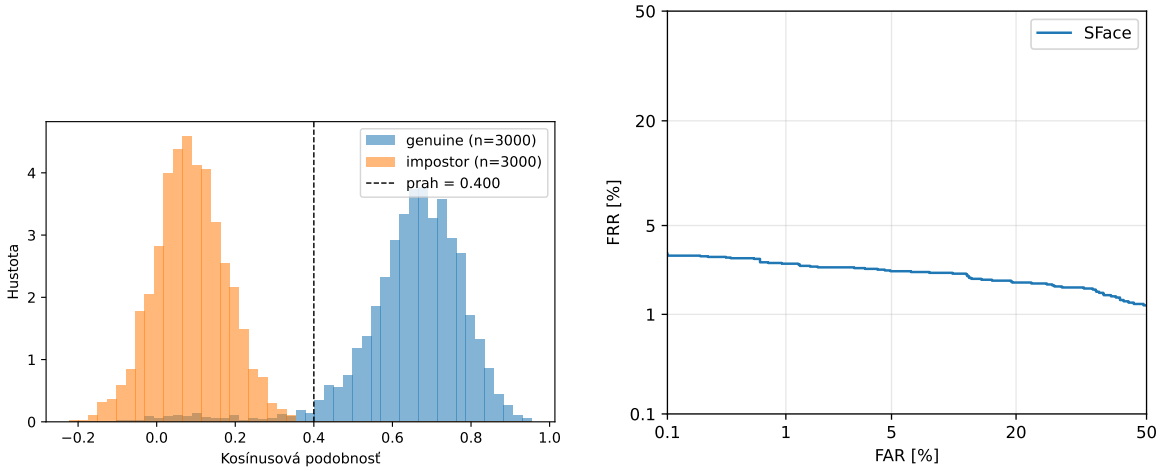
| Oblasť | Overované správanie |
|---|---|
| Poloha hlavy | znamienko yaw a pitch, nezávislosť od náklonu hlavy, degenerované body, výpočet polohy aj z rozmazanej snímky |
| Aktívna výzva | správny a nesprávny smer, nedostatočný pohyb, málo snímok s tvárou, náhodnosť poradia |
| Metriky | FAR/FRR, EER (aj analyticky pre dve normálne rozdelenia), APCER/BPCER/ACER |
| Bezpečnosť | podpis a platnosť JWT, šifrovanie vzorov, produkčná konfigurácia, rate-limit |
| Výzvy | jednorazovosť, expirácia, kontrola účelu |
| End-to-end API | registrácia a overenie, impostor, neznámy používateľ, útok fotografiou (pasívny aj aktívny), zámena osoby počas relácie, opakované použitie výzvy, chýbajúci krok, duplicitná tvár, identifikácia 1:N, zablokovanie účtu, výmaz účtu, práva administrátora, história zamietnutých pokusov |
| Klient | výpočet pohybu hlavy, medián neutrálnej polohy, preklad chybových hlásení |

## 5.3 Presnosť rozpoznávania tváre

Model SFace sme vyhodnotili na databáze Labeled Faces in the Wild [19] podľa protokolu *pairs* – 6000 dvojíc fotografií, z toho 3000 dvojíc tej istej osoby a 3000 dvojíc rôznych osôb. Kontrolu kvality sme pri tomto meraní vypli, aby sme merali samotný model rozpoznávania. Tvár sa našla na všetkých 12 000 fotografiách (FTA 0 %). Výsledky sú v tabuľke 5.2 a na obr. 5.1.

Tabuľka 5.2: Výsledky rozpoznávania tváre na LFW (6000 dvojíc)

| Pracovný bod | Prah | FAR [%] | FRR [%] |
|---|---|---|---|
| EER | 0,266 | 2,47 | 2,47 |
| Systémový prah | 0,400 | 0,00 | 3,90 |
| FAR $\leq$ 1 % | 0,294 | 1,00 | 2,63 |
| FAR $\leq$ 0,1 % | 0,339 | 0,10 | 3,03 |




(a) Rozdelenie skóre

(b) DET krivka

Obr. 5.1: Rozpoznávanie tváre na LFW

Rozdelenia skóre dvojíc tej istej osoby a rôznych osôb sa prekrývajú len málo. Pri použitom prahu 0,40 nevznikla v 3000 porovnaniach rôznych osôb ani jedna falošná zhoda, cenou je odmietnutie 3,9 % dvojíc tej istej osoby. Databáza LFW obsahuje fotografie z rôznych rokov, s rôznou pózou a osvetlením, čo je náročnejšia situácia ako prihlasovanie pred vlastnou webkamerou. Pri prihlasovaní sa navyše vzor relácie počíta z viacerých snímok, čo náhodné výkyvy ďalej zmierňuje. Prah 0,40 preto považujeme za vhodný kompromis medzi bezpečnosťou a pohodlím.

## 5.4 Presnosť pasívnej detekcie útokov

Na vyhodnotenie sme použili testovaciu časť verejnej databázy CASIA-FASD [20], konkrétne 2408 snímok vybraných z jej videí. Databáza obsahuje živé tváre a tri druhy útokov (tab. 5.3). Snímky v použitej verzii databázy sú už orezané okolo tváre na 256 $\times$ 256 px, takže modely MiniFASNet nevidia celé okolie tváre, s ktorým počítajú. Výsledky sú preto skôr pesimistickým odhadom.

Tabuľka 5.3: Dataset pre vyhodnotenie pasívnej detekcie (CASIA-FASD, testovacia časť)

| Trieda | Popis | Snímky |
|---|---|---|
| `bona_fide` | živé tváre | 591 |
| `print_warped` | vytlačená fotografia, ohýbaná pred kamerou | 712 |
| `print_cut` | vytlačená fotografia s vystrihnutými očami | 536 |
| `replay` | video prehrávané na displeji | 569 |

Pri pôvodnom prahu 0,70 boli útoky zachytené takmer úplne (APCER najviac 0,93 %), no odmietnutých bolo 34 % snímok živých tvárí. Taký prah by v praxi viedol k častému odmietaniu skutočných používateľov. Tabuľka 5.4 ukazuje, ako sa chyby menia s prahom.

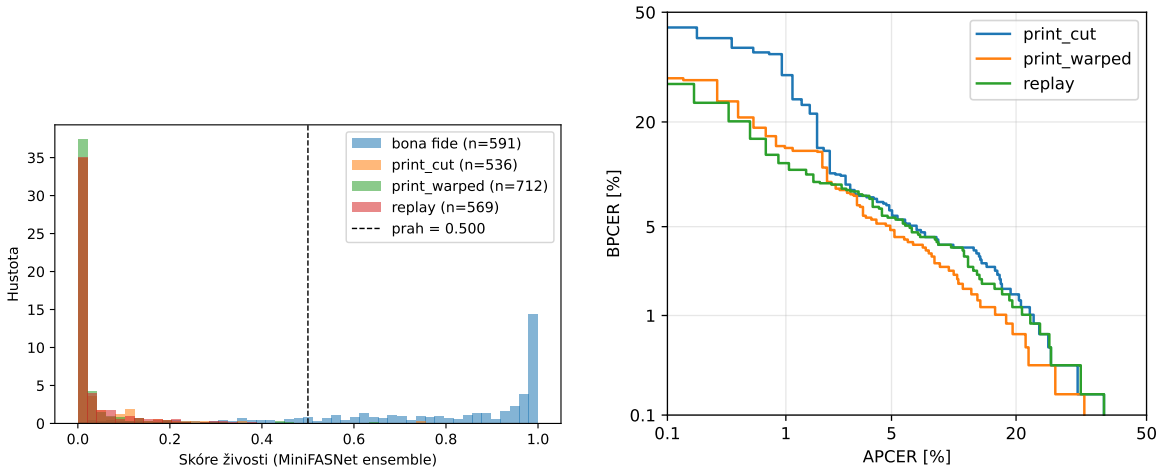
Tabuľka 5.4: Chyby pasívnej detekcie pri rôznych prahoch (úroveň snímok)

| Prah | BPCER [%] | APCER print_warped | APCER print_cut | APCER replay |
|---|---|---|---|---|
| 0,20 | 5,58 | 3,93 | 5,97 | 5,62 |
| 0,30 | 8,63 | 2,67 | 2,99 | 2,64 |
| 0,40 | 12,86 | 1,83 | 2,05 | 0,88 |
| 0,50 | 18,10 | 0,70 | 1,68 | 0,53 |
| 0,60 | 25,21 | 0,28 | 1,12 | 0,18 |
| 0,70 | 34,35 | 0,00 | 0,93 | 0,00 |

Prah sme znížili na 0,50. Na úrovni jednej snímky pri ňom APCER neprekročí 1,7 % pri žiadnom type útoku. BPCER 18 % sa týka jednotlivých snímok – pri prihlásení sa skóre priemeruje cez približne sedem frontálnych snímok, takže náhodne nízke skóre jednej snímky reláciu nezamietne. Útoky, ktoré by pasívna detekcia prepustila, musia navyše prejsť aktívnou výzvou. Výsledky pri systémovom prahu sú v tabuľke 5.5.

Tabuľka 5.5: Výsledky pasívnej detekcie útokov na CASIA-FASD (prah 0,50)

| Metrika | Hodnota [%] |
|---|---|
| APCER (print_warped) | 0,70 |
| APCER (print_cut) | 1,68 |
| APCER (replay) | 0,53 |
| APCER (max) | 1,68 |
| BPCER | 18,10 |
| ACER | 9,89 |
| EER | 5,25 |
| BPCER20 (APCER = 5 %) | 5,58 |
| BPCER100 (APCER = 1 %) | 16,58 |




(a) Rozdelenie skóre živosti

(b) DET (APCER vs. BPCER)

Obr. 5.2: Pasívna detekcia prezentačných útokov na CASIA-FASD

Z histogramu je vidieť, že skóre takmer všetkých útokov je blízko nuly a útoky sa líšia len v tom, ako často sa objaví výnimka. Najťažšie odhaliteľná je fotografia s vystrihnutými očami, pri ktorej sú v obraze skutočné oči útočníka. Živé tváre majú skóre rozložené širšie, čo súvisí s nižšou kvalitou videí v databáze a s orezaním okolia tváre.

## 5.5 Testy celého systému

### Útok statickým obrázkom

Útok statickým obrázkom sme vyskúšali dvoma spôsobmi. V prvom sme do prehliadača podstrčili virtuálnu kameru, ktorej obraz tvorila umelo vygenerovaná fotografia tváre, a

prešli sme bežným prihlásením cez webové rozhranie. Pasívna detekcia v tomto prípade obraz nezamietla (skóre živosti 0,98) – obrázok vložený priamo do video toku nemá žiadne stopy tlače ani displeja, ide teda v skutočnosti o injekčný útok. Zachytila ho až aktívna výzva, pretože tvár sa v žiadnom kroku nepohla (obr. 4.3b). Počas tvorby snímok obrazovky sme takto vykonali 6 pokusov a všetky boli zamietnuté s dôvodom `active_challenge_failed`.

V druhom teste sme ten istý obrázok poslali 30-krát priamo cez API (režim identifikácie), s drobným posunom a šumom medzi snímkami a so stratovou kompresiou JPEG podobne ako pri skutočnej kamere. Všetkých 30 relácií bolo zamietnutých už pasívnou detekciou (`passive_spoof`); priemerné skóre živosti relácie bolo 0,25 (od 0,04 do 0,52). Oba testy ukazujú, prečo systém používa obe vrstvy: každá zachytila prípad, ktorý by druhá prepustila.

Tabuľka 5.6: Útok statickým obrázkom

| Spôsob útoku | Pokusy | Zamietnuté | Vrstva, ktorá útok zachytila |
|---|---|---|---|
| Virtuálna kamera v prehliadači | 6 | 6 | aktívna výzva |
| Priame volanie API | 30 | 30 | pasívna detekcia |

## Test so živými používateľmi

Úspešnosť prihlásenia skutočných používateľov a odolnosť proti fyzickým útokom (vytlačená fotografia, displej mobilu, video s pohybmi hlavy) sa dá zmerať iba s reálnymi ľuďmi pred kamerou. Postup a scenáre sú v tabuľke 5.7; výsledky sa čerpajú z auditného záznamu skriptom `python -m evaluation.audit_report`.

Tabuľka 5.7: Scenáre testu so živými používateľmi

| Scenár | Pokusy | Očakávaný výsledok | Úspešnosť [%] |
|---|---|---|---|
| Registrovaný používateľ, 1:1 | **[TODO: ]** | prijatie | **[TODO: ]** |
| Registrovaný používateľ, 1:N | **[TODO: ]** | prijatie | **[TODO: ]** |
| Iná osoba s menom obete | **[TODO: ]** | `no_match` | **[TODO: ]** |
| Vytlačená fotografia obete | **[TODO: ]** | zamietnutie | **[TODO: ]** |
| Fotografia na mobile/monitore | **[TODO: ]** | zamietnutie | **[TODO: ]** |
| Video obete s pohybmi hlavy | **[TODO: ]** | zamietnutie | **[TODO: ]** |
| Zámena osoby počas snímania | **[TODO: ]** | `identity_inconsistent` | **[TODO: ]** |

## 5.6 Výkon

Latenciu sme merali skriptom `evaluation.benchmark` na notebooku s procesorom Intel Core i7-13650HX (ONNX Runtime na CPU, bez GPU), 200 opakovaní, na snímke v rozlíšení 640 × 360 px, ktoré posiela klient.

Tabuľka 5.8: Latencia spracovania jednej snímky (640 × 360 px)

| Fáza | Priemer [ms] | Medián [ms] | P95 [ms] |
|---|---:|---:|---:|
| Detekcia (YuNet) | 4,76 | 4,65 | 5,50 |
| Kontrola kvality | 0,10 | 0,10 | 0,11 |
| Odhad polohy hlavy | 0,01 | 0,01 | 0,01 |
| Pasívna živosť (2× MiniFASNet) | 2,59 | 2,53 | 2,90 |
| Extrakcia príznakov (SFace) | 3,98 | 3,95 | 4,38 |
| Celá snímka | 12,23 | 12,06 | 13,31 |

Relácia má najviac 27 snímok, jej spracovanie na serveri teda trvá približne 0,3 s. Pre porovnanie, pri snímke $1280 \times 720$ px trvá samotná detekcia 18 ms a celá snímka 26 ms, preto klient snímky pred odoslaním zmenšuje. Celkovú dobu prihlásenia (približne 5–7 s) určuje najmä čas, ktorý používateľ potrebuje na vykonanie pohybov. Na bezplatnej inštancii služby Render je spracovanie pomalšie a prvá požiadavka po nečinnosti trvá až desiatky sekúnd, kým sa inštancia spustí.

# Kapitola 6

# Príručka a dokumentácia

## 6.1 Archivácia a reprodukovateľnosť

Zdrojový kód, dokumentácia, vyhodnocovacie skripty aj táto správa sú v repozitári `https://github.com/opoiasnik/face-auth-antispoofing`. Reprodukovateľnosť zabezpečujú:

- skript na stiahnutie modelov s kontrolnými súčtami SHA-256,
- databázové migrácie (Alembic) – schéma sa vytvorí automaticky,
- uzamknuté verzie závislostí klienta (`package-lock.json`),
- Docker obrazy a súbor `docker-compose.yml` pre spustenie jedným príkazom,
- automatické testy spúšťané v GitHub Actions pri každej zmene,
- vyhodnocovacie skripty, ktoré sami stiahnu verejné dáta (LFW) alebo pracujú s priečinkom s jasne danou štruktúrou (CASIA-FASD, vlastné nahrávky).

Podrobná technická dokumentácia je v priečinku `docs/` repozitára: architektúra (`architecture.md`), popis REST API (`api.md`), používateľská príručka (`user-guide.md`) a metodika vyhodnotenia (`evaluation.md`).

## 6.2 Inštalácia a spustenie

### Lokálne spustenie

Požiadavky: Python 3.11 alebo novší, Node.js 20 alebo novší, webkamera.

Listing 6.1: Spustenie servera

```
cd backend
python -m venv .venv
```

```
.venv/Scripts/activate        # Linux/macOS: source .venv/bin/activate
pip install -e ".[dev,eval]"
python scripts/download_models.py
uvicorn app.main:create_app --factory --port 8000
```

Listing 6.2: Spustenie klienta

```
cd frontend
npm ci
npm run dev                   # http://localhost:5173
```

## Spustenie v Dockeri

```
cp .env.example .env
docker compose up -d --build  # http://localhost:8080
```

Pri produkčnom nasadení treba nastaviť `FA_ENVIRONMENT=production`, vygenerovať tajomstvá príkazom `python -m app.cli generate-secrets` a aplikáciu sprístupniť cez HTTPS – prehliadač inak nepovolí prístup ku kamere.

## Vyhodnotenie

```
python -m evaluation.evaluate_recognition --lfw
python -m evaluation.evaluate_pad --dir data/pad
python -m evaluation.benchmark --image tvar.jpg --runs 200
python -m evaluation.audit_report
```

## Konfigurácia

Prahy a limity sa nastavujú premennými prostredia s predponou `FA_` (tab. 6.1).

Tabuľka 6.1: Najdôležitejšie konfiguračné premenné

| Premenná | Predvolená | Význam |
|---|---|---|
| `FA_MATCHING__THRESHOLD` | 0,40 | prah kosínusovej podobnosti |
| `FA_PASSIVE_LIVENESS__THRESHOLD` | 0,50 | prah skóre živosti |
| `FA_ACTIVE_LIVENESS__STEPS` | 2 | počet náhodných pohybov vo výzve |
| `FA_ACTIVE_LIVENESS__YAW_THRESHOLD` | 0,20 | minimálne otočenie hlavy |
| `FA_ACTIVE_LIVENESS__PITCH_THRESHOLD` | 0,07 | minimálny pohyb hore/dole |
| `FA_CHALLENGE__ACTION_TIMEOUT_MS` | 5000 | najdlhšie trvanie pohybového kroku |
| `FA_SECURITY__LOCKOUT_MAX_FAILURES` | 5 | neúspechy do zablokovania |
| `FA_SECURITY__EXPOSE_SCORES` | true | vracanie skóre (v produkcii false) |
| `FA_DATABASE_URL` | SQLite | pripojenie k databáze |
| `FA_REDIS_URL` | – | zdieľané výzvy pri viacerých procesoch |

## 6.3 Používateľská príručka

### Registrácia

1. Na stránke *Registrovať* zadajte používateľské meno (3–32 znakov: malé písmená, číslice, bodka, pomlčka, podčiarkovník), voliteľne meno a kliknite na *Pokračovať*.

2. Povoľte prístup ku kamere a umiestnite tvár do kruhu. Keď sa prstenec okolo kruhu zafarbí nazeleno a zobrazí sa „Tvár je v poriadku“, kliknite na *Začať*.

3. Pozrite sa do kamery a potom urobte pohyby podľa pokynu pod kruhom (napríklad „Otočte hlavu doľava“); smer ukazuje aj šípka v kruhu. Krok sa ukončí sám, keď systém pohyb rozpozná. Poradie pohybov je pri každom pokuse iné.

4. Po úspešnom overení sa vytvorí účet a používateľ je prihlásený.

### Prihlásenie

Štandardne sa zadáva meno (verifikácia 1:1). Odkaz *Prihlásiť sa bez mena* prepne na identifikáciu 1:N iba podľa tváre. Postup snímania je rovnaký ako pri registrácii. Po piatich neúspešných pokusoch počas 15 minút sa účet dočasne zablokuje.

### Riešenie problémov

Tabuľka 6.2: Časté hlásenia a ich riešenie

| Hlásenie | Riešenie |
|---|---|
| Kamera nie je dostupná | povoľte kameru v nastaveniach stránky a kliknite na *Povoliť kameru* |
| Nevidíme vašu tvár / Podíďte bližšie | tvár do kruhu, bližšie ku kamere |
| Je príliš tma / Je príliš svetla | otočte sa k zdroju svetla, nesedte proti oknu |
| Nerozpoznali sme … | urobte uvedený pohyb výraznejšie, až keď sa zobrazí pokyn |
| Vyzerá to na fotografiu alebo obrazovku | nepoužívajte fotografiu ani displej; pri falošnom poplachu zlepšite osvetlenie |
| Tvár sa nezhoduje s účtom | zlepšite svetlo; pri zmene vzhľadu aktualizujte vzor v účte |
| Príliš veľa pokusov | počkajte 15 minút |

### Používateľský účet a administrácia

V účte je história všetkých pokusov o prihlásenie vrátane neúspešných, možnosť aktualizovať vzor tváre (nový vzor sa musí zhodovať s pôvodným) a natrvalo vymazať účet aj vzor (obr. 4.4). Rolu administrátora prideľuje príkaz `python -m app.cli promote <meno>`. Administrátor vidí štatistiky úspešnosti, dôvody zamietnutí, zoznam používateľov (blokovanie, odstránenie) a celý auditný záznam.

## 6.4 Rozhranie REST API

Tabuľka 6.3: Hlavné koncové body API (predpona `/api/v1`)

| Metóda | Cesta | Popis |
|---|---|---|
| POST | `/challenges` | vydanie jednorazovej výzvy |
| POST | `/biometrics/quality` | kvalita a poloha hlavy na jednej snímke |
| POST | `/enrollment` | registrácia, vráti JWT |
| POST | `/auth/verify` | overenie 1:1, vráti JWT |
| POST | `/auth/identify` | identifikácia 1:N, vráti JWT |
| GET | `/users/me/attempts` | história vlastných pokusov |
| PUT | `/users/me/face` | aktualizácia vzoru |
| DELETE | `/users/me` | výmaz účtu a vzoru |
| GET | `/admin/stats`, `/admin/attempts` | štatistiky a audit (administrátor) |

Úplný popis vrátane formátu chýb je v súbore `docs/api.md` a v interaktívnej dokumentácii `/docs` (dostupná mimo produkčného režimu).

# Kapitola 7

# Záver

V projekte sme navrhli, implementovali a nasadili webový systém na prihlasovanie tvárou s viacvrstvovou ochranou proti prezentačným útokom. Systém tvár sníma bežnou webkamerou, všetky rozhodnutia robí na serveri a kombinuje kontrolu kvality snímky, pasívnu detekciu podvrhu modelmi MiniFASNet, náhodnú výzvu na pohyb hlavy a kontrolu konzistencie identity počas snímania. Tvár porovnáva modelom SFace a uložené vzory šifruje.

Meranie ukázalo, že rozpoznávanie dosahuje na databáze LFW EER 2,47 % a pri použitom prahu 0,40 nevzniklo ani jedno falošné prijatie. Pasívna detekcia mala na databáze CASIA-FASD EER 5,25 %. Meranie zároveň odhalilo, že pôvodný prah 0,70 zamietal príliš veľa živých tvárí, preto sme ho znížili na 0,50, pri ktorom APCER neprekročí 1,7 %. Pri teste statickým obrázkom sa ukázalo, že vrstvy sa dopĺňajú: obraz vložený cez virtuálnu kameru prešiel pasívnou detekciou, ale zastavila ho aktívna výzva, a naopak snímky poslané priamo cez API zachytila pasívna detekcia. Spracovanie relácie trvá na bežnom procesore približne 0,3 s.

Počas testovania sme na základe nameraných výsledkov upravili aj samotný systém: výzva sa namiesto pevného času prispôsobuje pohybu používateľa, poloha hlavy sa počíta aj z rozmazaných snímok, pasívna detekcia sa vyhodnocuje len na frontálnych snímkach a opravili sme chybu pri spúšťaní kamery.

Systém má aj obmedzenia. Poloha hlavy sa odhaduje len z piatich bodov, takže je menej presná ako odhad z hustej siete bodov. Proti injekčným útokom cez virtuálnu kameru chráni iba aktívna výzva – dostatočne sofistikovaný útok, ktorý by v reálnom čase generoval pohyby tváre, by vyžadoval ďalšie opatrenia, napríklad atestáciu zariadenia. Pasívnu detekciu sme vyhodnotili na staršej databáze s orezanými snímkami a test so živými používateľmi v širšom rozsahu zostáva na doplnenie. Ako rozšírenie sa ponúka použitie modelov detekcie s lepšou generalizáciou [11], detekcia injekčných útokov a ochrana vzorov zrušiteľnou biometriou [15].

# Zoznam použitej literatúry


[1] EUROPEAN UNION AGENCY FOR CYBERSECURITY (ENISA). *Remote Identity Proofing: Attacks & Countermeasures*. Athens: ENISA, 2022. Dostupné z: `https://www.enisa.europa.eu/publications/remote-identity-proofing-attacks-countermeasures`

[2] WU, Wei, PENG, Hanyang a YU, Shiqi. YuNet: A Tiny Millisecond-level Face Detector. *Machine Intelligence Research*. 2023, roč. 20, č. 5, s. 656–665. DOI: 10.1007/s11633-023-1423-y

[3] DENG, Jiankang, GUO, Jia, YANG, Jing, XUE, Niannan, KOTSIA, Irene a ZAFEIRIOU, Stefanos. ArcFace: Additive Angular Margin Loss for Deep Face Recognition. *IEEE Transactions on Pattern Analysis and Machine Intelligence*. 2022, roč. 44, č. 10, s. 5962–5979. DOI: 10.1109/TPAMI.2021.3087709

[4] KIM, Minchul, JAIN, Anil K. a LIU, Xiaoming. AdaFace: Quality Adaptive Margin for Face Recognition. In: *2022 IEEE/CVF Conference on Computer Vision and Pattern Recognition (CVPR)*. IEEE, 2022, s. 18729–18738. DOI: 10.1109/CVPR52688.2022.01819

[5] ZHONG, Yaoyao, DENG, Weihong, HU, Jiani, ZHAO, Dongyue, LI, Xian a WEN, Dongchao. SFace: Sigmoid-Constrained Hypersphere Loss for Robust Face Recognition. *IEEE Transactions on Image Processing*. 2021, roč. 30, s. 2587–2598. DOI: 10.1109/TIP.2020.3048632

[6] SCHLETT, Torsten, RATHGEB, Christian, HENNIGER, Olaf, GALBALLY, Javier, FIERREZ, Julian a BUSCH, Christoph. Face Image Quality Assessment: A Literature Survey. *ACM Computing Surveys*. 2022, roč. 54, č. 10s, s. 1–49. DOI: 10.1145/3507901

[7] ISO/IEC 29794-5:2025. *Information technology – Biometric sample quality – Part 5: Face image data*. 1. vyd. Ženeva: ISO, 2025. Dostupné z: `https://www.iso.org/standard/81005.html`

[8] HERNANDEZ-ORTEGA, Javier, FIERREZ, Julian, MORALES, Aythami a GALBALLY, Javier. Introduction to Presentation Attack Detection in Face Biometrics and Recent Advances. In: MARCEL, Sébastien, FIERREZ, Julian a EVANS, Nicholas (ed.). *Handbook of Biometric Anti-Spoofing: Presentation Attack Detection and Vulnerability Assessment*. 3. vyd. Singapore: Springer, 2023, s. 203–230. DOI: 10.1007/978-981-19-5288-3_9

[9] YU, Zitong, QIN, Yunxiao, LI, Xiaobai, ZHAO, Chenxu, LEI, Zhen a ZHAO, Guoying. Deep Learning for Face Anti-Spoofing: A Survey. *IEEE Transactions on Pattern Analysis and Machine Intelligence*. 2023, roč. 45, č. 5, s. 5609–5631. DOI: 10.1109/TPAMI.2022.3215850

[10] SUN, Yiyou, LIU, Yaojie, LIU, Xiaoming, LI, Yixuan a CHU, Wen-Sheng. Rethinking Domain Generalization for Face Anti-spoofing: Separability and Alignment. In: *2023 IEEE/CVF Conference on Computer Vision and Pattern Recognition (CVPR)*. IEEE, 2023, s. 24563–24574. DOI: 10.1109/CVPR52729.2023.02353

[11] SRIVATSAN, Koushik, NASEER, Muzammal a NANDAKUMAR, Karthik. FLIP: Cross-domain Face Anti-spoofing with Language Guidance. In: *2023 IEEE/CVF International Conference on Computer Vision (ICCV)*. IEEE, 2023, s. 19628–19639. DOI: 10.1109/ICCV51070.2023.01803

[12] WANG, Dong, GUO, Jia, SHAO, Qiqi et al. Wild Face Anti-Spoofing Challenge 2023: Benchmark and Results. In: *2023 IEEE/CVF Conference on Computer Vision and Pattern Recognition Workshops (CVPRW)*. IEEE, 2023, s. 6380–6391. DOI: 10.1109/CVPRW59228.2023.00679

[13] ISO/IEC 30107-3:2023. *Information technology – Biometric presentation attack detection – Part 3: Testing and reporting*. 2. vyd. Ženeva: ISO, 2023. Dostupné z: `https://www.iso.org/standard/79520.html`

[14] BUSCH, Christoph. Standards for Biometric Presentation Attack Detection. In: MARCEL, Sébastien, FIERREZ, Julian a EVANS, Nicholas (ed.). *Handbook of Biometric Anti-Spoofing: Presentation Attack Detection and Vulnerability Assessment*. 3. vyd. Singapore: Springer, 2023, s. 571–583. DOI: 10.1007/978-981-19-5288-3_21

[15] ABDULLAHI, Sani M., SUN, Shuifa, WANG, Beng, WEI, Ning a WANG, Hongxia. Biometric Template Attacks and Recent Protection Mechanisms: A Survey. *Information Fusion*. 2024, roč. 103, čl. 102144. DOI: 10.1016/j.inffus.2023.102144

[16] EURÓPSKY PARLAMENT A RADA EURÓPSKEJ ÚNIE. Nariadenie (EÚ) 2024/1689 z 13. júna 2024, ktorým sa stanovujú harmonizované pravidlá v oblasti

umelej inteligencie (akt o umelej inteligencii). *Úradný vestník Európskej únie*, L, 2024/1689. Dostupné z: https://eur-lex.europa.eu/eli/reg/2024/1689/oj

[17] OPENCV. *OpenCV Zoo: Models for OpenCV DNN* [softvér]. Dostupné z: https://github.com/opencv/opencv_zoo

[18] MINIVISION AI. *Silent-Face-Anti-Spoofing* [softvér]. 2020. Dostupné z: https://github.com/minivision-ai/Silent-Face-Anti-Spoofing

[19] HUANG, Gary B., RAMESH, Manu, BERG, Tamara a LEARNED-MILLER, Erik. *Labeled Faces in the Wild: A Database for Studying Face Recognition in Unconstrained Environments*. Technical Report 07-49. Amherst: University of Massachusetts, 2007.

[20] ZHANG, Zhiwei, YAN, Junjie, LIU, Sifei, LEI, Zhen, YI, Dong a LI, Stan Z. A Face Antispoofing Database with Diverse Attacks. In: *2012 5th IAPR International Conference on Biometrics (ICB)*. IEEE, 2012, s. 26–31. DOI: 10.1109/ICB.2012.6199754

# Dodatok A

# Obsah repozitára

Repozitár `https://github.com/opoiasnik/face-auth-antispoofing`:

- `backend/` – serverová aplikácia, testy, vyhodnocovacie skripty,
- `frontend/` – klientska aplikácia,
- `docs/` – technická dokumentácia,
- `report/` – zdrojové súbory tejto správy,
- `docker-compose.yml`, `render.yaml` – nasadenie.

# Dodatok B

# Ukážka odpovede API

Listing B.1: Zamietnutie relácie pri útoku statickým obrázkom

```
HTTP/1.1 401 Unauthorized
{
  "error": {
    "code": "biometric_rejected",
    "message": "Liveness challenge was not completed",
    "details": {
      "reason": "active_challenge_failed",
      "passive_liveness": 0.9592,
      "active_liveness": {
        "passed": false,
        "steps": [
          {"action": "center",    "passed": true,  "usable_frames": 7,  "
   peak_delta": 0.1045},
          {"action": "look_up",   "passed": false, "usable_frames": 10, "
   peak_delta": 0.0},
          {"action": "look_down", "passed": false, "usable_frames": 10, "
   peak_delta": 0.0}
        ]
      },
      "consistency": 1.0,
      "quality_issues": {},
      "failed_action": "look_up"
    }
  }
}
```